Literature Survey and Requirement Analysis

Literature Survey and Requirement Analysis

Project Title: Risk-Adaptive Zero-Trust Security Architecture for Hybrid Cloud Infrastructure

Domain: Cloud & Cybersecurity

Keywords: Zero Trust, Hybrid Cloud, Risk-Adaptive Access Control, Behavioral Anomaly Detection, Identity and Access Management

---

1. Introduction to the Project Problem

Hybrid cloud environments combine private and public cloud resources to improve scalability, flexibility, and cost efficiency. However, this combination also expands the attack surface and introduces multiple trust boundaries. Users, devices, applications, and resources may exist across different administrative domains, so traditional perimeter-based security models cannot safely assume that anything inside a network is trustworthy.

The core problem this project addresses is the need for a security architecture that does not rely on implicit trust based on network location. Instead, it should continuously evaluate access requests using identity, device, behavioral, and resource context, and then respond with an adaptive decision such as Allow, Challenge, Restrict, or Block.

This problem is important because static access-control approaches are often too rigid to detect subtle suspicious behavior and too blunt to avoid disrupting legitimate activity. As organizations increasingly rely on hybrid cloud infrastructure, the ability to make risk-based access decisions in near real time becomes more important for reducing unauthorized access, lateral movement, and data exposure.

The proposed solution is expected to benefit:

- organizations operating hybrid cloud environments,
- users and administrators through more contextual access decisions,
- the academic and research community through a prototype and quantitative evaluation, and
- the project team by building practical skills in cloud infrastructure, identity and access management, anomaly detection, and security evaluation.

---

2. Search Strategy and Keywords

2.1 Search Approach

The literature survey was conducted by starting from the project description and breaking the work into major concepts and modules. For each concept, the search focused on identifying:

- foundational standards or architecture documents,

- survey or review papers where available,
- research papers proposing specific methods, models, or architectures,
- technical documentation for relevant platforms and technologies.

Preferred sources included IEEE Xplore, ACM Digital Library, ScienceDirect, SpringerLink, Wiley Online Library, Google Scholar, and official technical documentation or standards where appropriate. Blog posts and unverified articles were avoided for the core survey.

2.2 Keywords and Search Terms

The following keyword groups were used, both individually and in combination:

- Zero Trust, Zero Trust Architecture, Zero Trust Network Access
- Hybrid Cloud Security, Cloud Security, Multi-Cloud Security
- Risk-Adaptive Access Control, Context-Aware Access Control, Dynamic Access Control
- Behavioral Analytics, User and Entity Behavior Analytics, Anomaly Detection
- Machine Learning for Security, Insider Threat Detection
- Identity and Access Management, Authentication, Least Privilege
- Risk Scoring, Access Decision, Policy Engine
- Security Monitoring, Logging, Performance Evaluation, Authentication Overhead, Service Latency

These terms were derived from the project problem statement, objectives, methodology phases, and the proposed system workflow.

---

3. Summary of Selected Sources

> ***Note on sources:***
>
> *The sources below were selected because they are directly relevant to the major concepts in this project. Where a source could be verified through an accessible authoritative page or known publication record, that verified information is included. Where a specific paper or document could not be independently confirmed during this survey, it is marked as a candidate source and should be confirmed by the team before citation in any final submission.*

3.1 NIST SP 800-207, Zero Trust Architecture

- **Type of source:** Standards/technical publication
- **Publisher/accessibility:** NIST Computer Security Resource Center (CSRC)
- **What it addresses:** An abstract definition of Zero Trust Architecture and general deployment models and use cases where Zero Trust may improve an enterprise security posture.
- **Core ideas relevant to this project:**
- Zero Trust assumes no implicit trust based only on physical or network location or asset ownership.

- Authentication and authorization for both subject and device are discrete functions performed before a session to an enterprise resource is established.
- Zero Trust is described as a response to trends such as remote users, bring-your-own-device, and cloud-based assets outside the enterprise-owned network boundary.
- The focus is on protecting resources rather than network segments.
- **Relevance to this project:** This document supports the conceptual foundation for the project's Zero-Trust approach, especially the idea that access should be verified regardless of where the request originates and that authentication and authorization should be treated as explicit steps before granting access.

3.2 Zero Trust Architecture as a General Research and Practice Area

Several research and technical works in the broader Zero Trust literature discuss:

- moving from perimeter-based trust models to identity- and resource-centric models,
- continuous verification of users, devices, and sessions,
- policy-driven access decisions,
- integration with cloud and hybrid environments.

These themes align with the project's design goal of treating every access request as something to be evaluated rather than automatically trusted.

3.3 Hybrid Cloud Security and Trust Boundaries

Works in hybrid cloud security generally discuss:

- the difficulty of maintaining consistent security across private and public cloud resources,
- the challenges of heterogeneous environments,
- network topology, connectivity, and security boundaries between environments,
- the need for consistent identity, authentication, and access-policy enforcement across multiple platforms.

These topics are directly relevant to Phase 1 of the project methodology, which involves designing a hybrid cloud environment and documenting network topology, IP addressing, services, and security boundaries.

3.4 Risk-Adaptive and Context-Aware Access Control

Research and technical discussions on risk-based or context-aware access control commonly address:

- combining multiple signals such as identity, device posture, location, behavior, and request context,
- computing a risk level from those signals,
- mapping risk levels to access decisions or step-up authentication,
- balancing security and usability by avoiding one-size-fits-all rules.

This is closely related to the proposed risk-adaptive engine in the project, which is intended to integrate user identity and privileges, device context, behavioral anomaly score, requested

resource, request characteristics, and current security context.

3.5 Behavioral Anomaly Detection and UEBA-Related Approaches

Literature in user and entity behavior analytics and anomaly detection often covers:

- collecting logs and telemetry about authentication, access, and resource usage,
- building baselines of normal behavior,
- detecting deviations from those baselines,
- scoring or flagging suspicious activities,
- evaluating detection performance using metrics such as accuracy, false positives, and false negatives.

These ideas map directly to Project Phases 3 and 4, which involve collecting behavioral data, preparing datasets, establishing baselines, selecting anomaly-detection techniques, and generating anomaly scores.

3.6 Machine Learning for Anomaly Detection in Security Contexts

Machine-learning-based anomaly detection literature commonly discusses:

- supervised, unsupervised, and semi-supervised approaches,
- feature engineering from access logs and session data,
- challenges such as class imbalance, concept drift, and false alarms,
- evaluation using detection performance metrics and operational constraints.

This supports the project's need to select and test a suitable anomaly-detection model and to measure its behavior on normal and suspicious access patterns.

3.7 Security Monitoring, Logging, and Evaluation

Literature on security monitoring and system evaluation frequently emphasizes:

- centralized logging,
- structured event collection,
- observability for detection and response,
- measurable evaluation of security and performance characteristics such as response time, latency, and availability.

This supports the project's monitoring, attack-simulation, and evaluation phases.

3.8 Candidate Sources to Verify

The following are candidate sources that appear relevant but should be confirmed by the team before final citation:

- Additional IEEE or ACM survey papers on Zero Trust or risk-adaptive access control,
- Springer or ScienceDirect papers on behavioral anomaly detection for access control or insider threat,
- Recent conference or journal papers on hybrid cloud security architectures,
- Technical documentation for specific cloud platforms, identity services, or monitoring tools used in the prototype.

These are flagged as candidates because they were not individually verified during this survey pass.

3.9 Additional Literature Themes Relevant to This Project

The following themes were identified as relevant during the Week 2 survey and are discussed here at a level the team can support and still cite responsibly. They are not represented here by fabricated paper titles, authors, DOIs, or page numbers; where specific academic sources are added later, they should be confirmed through IEEE Xplore, ACM Digital Library, ScienceDirect, SpringerLink, Wiley Online Library, Google Scholar, or official standards/documentation before final citation.

Zero Trust as an identity- and resource-centric model.

Several Zero Trust works emphasize that trust should not be assumed from network location and that authentication and authorization for both subject and device should be treated as explicit steps before access is granted. This supports the project's verification-first design and its use of NIST SP 800-207 as conceptual grounding.

Risk-adaptive and context-aware access control.

Related work in risk-based and context-aware access control commonly describes the use of multiple contextual signals to compute a risk level and to choose an adaptive response, sometimes including step-up authentication. This aligns with the project's proposed combination of identity, device, behavioral, resource, and request context into an Allow/Challenge/Restrict/Block decision.

User and entity behavior analytics (UEBA) and anomaly detection.

Behavioral analytics literature often discusses collecting authentication and access telemetry, establishing baselines of normal behavior, detecting deviations, and scoring suspicious activity. This is directly relevant to the project's behavioral data collection and anomaly-detection phases.

Machine learning for anomaly detection in security data.

Machine-learning-based approaches are frequently discussed for detecting unusual patterns in security logs and sessions, with recurring evaluation concerns such as false positives, false negatives, class imbalance, concept drift, and operational overhead. These concerns shape how the project should select, train, test, and

evaluate its anomaly detection model.

Hybrid cloud security and cross-boundary enforcement.

Hybrid cloud security literature emphasizes the difficulty of maintaining consistent security across private and public cloud resources, including trust boundaries, connectivity, identity federation, and policy consistency across heterogeneous environments. This is directly relevant to Phase 1 of the project methodology.

Security monitoring and quantitative evaluation.

Monitoring and evaluation literature supports centralized logging, structured event collection, and measurable evaluation of security and performance characteristics, which supports the project's attack-simulation and evaluation phases.

---

4. Comparative Literature Analysis

The table below compares the major lines of related work identified during the survey. Because the survey is based on verifiable core sources plus candidate academic literature, the comparison focuses on themes and approaches rather than on fabricated paper-level details.

Source Area	Problem Addressed	Method/Approach	Technology/Algorithm	Key Findings/Themes	Limitations	Relevance to This Project
---	---	---	---	---	---	---
NIST SP 800-207 Zero Trust Architecture	Static, perimeter-based trust models are inadequate for modern distributed enterprise environments	Abstract Zero Trust Architecture definition, deployment models, and use cases	Identity- and resource-centric security, discrete authentication and authorization before session establishment	Trust should not be assumed from network location; resources should be protected directly	High-level architectural guidance rather than a complete implementation blueprint for every environment	Provides the foundational Zero-Trust concepts used in the proposed architecture
Zero Trust research and practice literature	Need to continuously verify access in modern cloud and remote environments	Identity-centric access control, continuous verification, policy-driven access	Identity and access management, device/posture checks, policy engines	Access decisions should reflect current context rather than only network membership	Implementation details vary widely across solutions and environments	Supports the project's verification-first design and policy-driven decision process

Source Area	Problem Addressed	Method/Approach	Technology/Algorithm	Key Findings/Themes	Limitations	Relevance to This Project
Hybrid cloud security literature	Inconsistent security across private and public cloud boundaries	Architectural and operational approaches for spanning heterogeneous cloud environments	Multi-environment networking, identity federation, cross-domain policy enforcement	Hybrid environments create broader attack surfaces and require consistent controls	Complexity of integrating different providers and internal systems	Directly relevant to the hybrid cloud setup and security-boundary design in Phase 1
Risk-based/context-aware access control literature	Static rules can be too permissive or too restrictive	Risk or context evaluation before granting access, sometimes with step-up authentication	Contextual signals, risk scoring, adaptive decision logic	Using multiple contextual inputs can support more granular and adaptive decisions	Requires reliable context collection and careful tuning to avoid pooruser experience	Supports the project's Allow/Challenge/Restrict/Block decision model
Behavioral anomaly detection and UEBA-related literature	Detecting unusual or suspicious behavior from logs and telemetry	Baseline modeling, deviation detection, anomaly scoring	Behavioral analytics over authentication and access data, sometimes with statistical or machine-learning methods	Behavior-based detection can highlight subtle anomalies that static rules may miss	Dependent on data quality, baseline quality, and threshold tuning; false positives can be a challenge	Core input to the project's anomaly detection and risk scoring work
Machine learning for security anomaly detection	Identifying malicious or abnormal patterns in security data	Statistical and ML-based anomaly detection, feature extraction from logs/sessions	Various ML techniques depending on data and task	Models can learn complex patterns but need careful evaluation and monitoring	Issues such as imbalance, drift, and explainability can affect practical use	Supports Phase 4 model selection and evaluation

Source Area	Problem Addressed	Method/Approach	Technology/Algorithm	Key Findings/Themes	Limitations	Relevance to This Project
Security monitoring and performance evaluation literature	Need to observe, measure, and improve security and system behavior	Centralized logging, event monitoring, quantitative evaluation	Logging and monitoring tooling, performance metrics	Measurable evaluation helps compare normal and adverse scenarios	Monitoring must be designed carefully to be useful without overwhelming operators	Supports Phase 6 and Phase 7 evaluation planning

---

5. Strengths and Limitations of Existing Approaches

5.1 Strengths

• Zero Trust thinking provides a clear conceptual shift away from implicit trust based on network location.

• Risk-adaptive and context-aware access control literature supports more flexible decisions than static allow/deny rules.

• Behavioral analytics and anomaly detection literature provide methods for detecting deviations from normal access patterns.

• Standards and architecture documentation help ground the project in established security concepts and terminology.

• Centralized monitoring and logging literature supports measurable evaluation and observability.

5.2 Limitations

• Many Zero Trust discussions are conceptual or architectural and may not fully specify how to integrate behavioral anomaly detection into access decisions in a single prototype.

• Risk-based access control approaches can require substantial context collection, tuning, and operational overhead.

• Anomaly detection models can be sensitive to data quality, baseline representation, and threshold selection, which can affect false-positive and false-negative behavior.

• Hybrid cloud deployments can involve heterogeneous platforms, making consistent enforcement and documentation more complex.

• Evaluation of security and performance together can be challenging, especially when both normal operation and simulated suspicious scenarios must be measured.

---

6. Identified Literature and Research Gap

Based on the survey, the following gap is identified:

Existing Zero Trust architecture guidance and related access-control research provide strong conceptual foundations for verifying users, devices, and sessions rather than trusting network location. At the same time, behavioral anomaly detection and risk-adaptive access control are often discussed in ways that are either relatively high level or focused on separate problems. There is limited evidence in the surveyed material of an integrated prototype that combines:

- a hybrid cloud environment with documented private and public cloud security boundaries,
- continuous behavioral anomaly scoring from access and authentication data,
- and a risk-adaptive policy engine that maps combined contextual signals to Allow, Challenge, Restrict, or Block decisions,

while also evaluating authentication overhead, access decision response time, service latency, and detection performance under both normal and controlled suspicious scenarios.

This gap matters because:

- Zero Trust principles alone do not automatically define how behavioral risk should influence access decisions in a specific hybrid cloud prototype.
- Behavioral detection alone does not necessarily connect anomaly scores to adaptive access-control actions.
- A combined approach is needed if the goal is to demonstrate not only that anomalies can be detected, but also that the system can respond adaptively and be evaluated quantitatively.

This project intends to address the gap by building a prototype that ties together hybrid cloud setup, identity and access control, behavioral data collection, anomaly detection, risk-adaptive decisioning, and measured evaluation.

---

7. Connection Between the Identified Gap and the Project

The proposed project connects to the identified gap in the following ways:

- It adopts the Zero Trust principle that access should be verified regardless of network location, using NIST SP 800-207 as a conceptual reference point.
- It extends the concept into a hybrid cloud prototype with private and public cloud resources and a controlled, monitored communication layer.
- It introduces behavioral anomaly detection as an explicit input to access decisions, not just as a standalone monitoring activity.
- It implements a risk-adaptive policy engine that combines identity, device, behavioral, resource, and request context into a risk score.
- It defines adaptive outcomes: Allow for low risk, Challenge for medium risk, Restrict for high risk, and Block for critical risk.
- It evaluates the system using quantitative metrics such as threat detection accuracy, false-positive rate, false-negative rate, authentication overhead, access decision response time, and service latency.

In this way, the project aims to move from general Zero Trust concepts toward a concrete, evaluated integration of behavioral anomaly detection and risk-adaptive access control in a hybrid

cloud setting.

---

8. Preliminary Requirement Analysis

These requirements are preliminary and may be refined during later phases.

8.1 Functional Requirements

The system should:

- authenticate users and devices before access is granted,
- verify every access request rather than trusting network location alone,
- collect access and authentication logs, including login time, access frequency, resource usage, and request characteristics,
- capture relevant device and session context,
- establish baseline profiles of normal behavior,
- compute anomaly scores for access activity,
- compute a risk score from multiple contextual signals,
- issue adaptive access decisions: Allow, Challenge, Restrict, or Block,
- provide centralized security logging and monitoring,
- support controlled generation of normal and suspicious access scenarios for evaluation,
- document the hybrid cloud topology, IP addressing, services, and security boundaries.

8.2 Non-Functional Requirements

The system should aim to:

- keep authentication overhead and access-decision response time acceptable for normal use,
- maintain acceptable service latency even when security checks are applied,
- support measurable evaluation of detection accuracy, false-positive rate, and false-negative rate,
- be reliable enough for repeated evaluation under normal and simulated scenarios,
- preserve security boundaries between private and public cloud components,
- be usable enough that security decisions do not unnecessarily block legitimate activity,
- produce logs and monitoring data that are sufficiently structured for analysis.

8.3 Technical Requirements

The project is likely to require:

- a hybrid cloud setup with private and public cloud resources or instances,
- virtual machines or cloud instances for the prototype environment,
- a controlled and monitored communication layer between cloud environments,
- identity and access management mechanisms for authentication and least-privilege policies,

- logging and monitoring tools for centralized security data collection,
- a dataset or data pipeline for behavioral access data,
- preprocessing and normalization capabilities for collected data,
- an anomaly-detection method or model suitable for behavioral data,
- a risk-scoring and policy engine component,
- Linux administration and command-line skills for environment setup and operation,
- version control using Git/GitHub for collaborative development,
- Python or a similar language for prototyping, data handling, and integration work.

---

9. Conclusion

The literature survey indicates that the proposed project is justified by a clear gap between broad Zero Trust principles and the practical integration of behavioral anomaly detection with risk-adaptive access control in a hybrid cloud prototype. Foundational architecture guidance, hybrid cloud security concerns, risk-based access control ideas, behavioral analytics, machine-learning-based anomaly detection, and security monitoring all contribute relevant concepts. However, the project's specific combination of components and its emphasis on quantitative evaluation across normal and controlled suspicious scenarios gives it a clear rationale and a concrete direction for the work.

---

10. References

1. NIST Computer Security Resource Center. *SP 800-207, Zero Trust Architecture*. National Institute of Standards and Technology. Available at the NIST CSRC publication page: https://csrc.nist.gov/pubs/sp/800/207/final, with the official publication link https://doi.org/10.6028/NIST.SP.800-207.

2. NIST CSRC publication record for SP 800-207 lists the following authors: Scott Rose (NIST), Oliver Borchert (NIST), Stu Mitchell (Stu2Labs), Sean Connelly (DHS).

3. Broader Zero Trust architecture research and practice literature, including identity-centric access control, continuous verification, and policy-driven access decision approaches. (To be confirmed with specific IEEE/ACM/Springer/ScienceDirect sources during the next literature pass.)

4. Hybrid cloud security literature on cross-environment trust boundaries, heterogeneous cloud integration, and consistent security enforcement. (To be confirmed with specific sources during the next literature pass.)

5. Risk-based and context-aware access control literature on adaptive decisions, contextual signal combination, and step-up authentication. (To be confirmed with specific sources during the next literature pass.)

6. User and entity behavior analytics and anomaly detection literature on baseline modeling, deviation detection, and anomaly scoring from access and authentication data. (To be confirmed

with specific sources during the next literature pass.)

7. Machine learning literature for security anomaly detection, including supervised, unsupervised, and semi-supervised approaches and common evaluation concerns. (To be confirmed with specific sources during the next literature pass.)

8. Security monitoring and performance evaluation literature on centralized logging, event observability, and quantitative evaluation metrics. (To be confirmed with specific sources during the next literature pass.)

Prepared by: Farhaan Pasha (R23EK009)

Team: Farhaan Pasha, Mayank Kaira, Shubham Kumar Pandey, Sudhanshu Bharadwaj, Syed Sulaiman

Faculty Guide: Mr. Hidam Rameshwar Singh

Status: Preliminary literature survey and requirement analysis; candidate academic sources still need confirmation before final submission.